XYZ - Technology Services

Information Security Management Committee

Terms of Reference

Document Number: XYZ -TS-IS-MN-003

Classification: Internal

Owner: Chief Digital Officer (CDO)

Effective Date: 15-Sep-2021

Version Number: 2.0

CS5292 W6 · D03 · sanitised for teaching

Document History:

Release Date	Revision No	Author(s)	Description	Reviewed & Approved By	Next review date
15-Sep-2021	1.0	ISO	Approved Document	ISMC	Sep-2022
20-Sep-2022	1.0	ISO	Approved Document	ISMC	Sep-2023
05-Sep-2023	1.0	ISO	Approved Document	ISMC	Sep-2024
01-Mar-2025	2.0	ISO	Transition	ISMC	Mar-2025

CS5292 W6 · D03 · sanitised for teaching

Contents

1. Purpose 4
2. Distribution 4
3. Scope 4
4. Definition 4
5. ISMC Members 4
6. ISMC Mandate and Responsibilities 5
7. Conduct and Frequency of Meetings 6
8. Inputs to the ISMC 6
9. Outputs to the ISMC 7
10. Reporting 7
11. Support 7

CS5292 W6 · D03 · sanitised for teaching

1. Purpose

The Information Security Steering Committee (ISMC) is a committee established by the senior management of XYZ - Holding Technology Services (Referred to as "XYZ-TS" hereafter), to provide the oversight role to XYZ-TS Information Security operations and fulfill the management review requirements set out by the ISO/IEC 27001:2022 standard. This document describes the roles, authorities and responsibilities of the ISMC.

2. Distribution

This is an internal document and should only be shared with employees of XYZ-TS and intended parties determined by the Information Security Officer (ISO).

3. Scope

XYZ-TS ISMC will constitute senior management and management of XYZ-TS along with ISO. ISMC will oversee the Information Security Management System (ISMS) at XYZ-TS and ensure the information security and XYZ-TS strategic objectives are met.

4. Definition

ISMC	Information Security Steering Committee at XYZ-TS
ISMS	Information Security Management System (ISMS) is the management system implemented at XYZ-TS to ensure the information security of the processes.

5. ISMC Members

The standing members of the ISMC shall be constituted by the following officers at XYZ-TS.

#	Designation	ISMC Role
1	Chief Digital Officer	Chairperson
2	Director - IT	Committee Member
3	Head – IT Infrastructure Governance and Data Protection	Committee Member
4	Head – SOC	Committee Member
5	Head - HR	Committee Member

CS5292 W6 · D03 · sanitised for teaching

6	Information Security Officer (ISO)	Committee Member

The following may be permitted to attend the meetings of the ISMC by invitation as and when required:

#	Designation
1	A representative from an external legal Consultation Firm
2	Information Security Management System Auditor
3	ISMS Consultants
4	External Auditors
5	CEOs from Business Units
6	Cyber Security Consultants for the board

6. ISMC Mandate and Responsibilities

- Provide strategic direction for the company's information security, data security (including business continuity), and network security-related infrastructure and services, software and licensing agreements to support XYZ-TS business.
- Define and drive the organization-wide Information Security objectives, strategies, policies, and awareness.
- Approve all policy matters related to Information Security.
- Approve exceptions on a case-by-case basis when the requirements of the Information Security Policy Manual cannot be met, providing a timeline for the exception and following up the exception condition till the Security Policy requirements are met.
- Initiate discussion of Information Security concerns and issues arising from delivery functions and departments and ensure that appropriate advice is received, and effective procedures implemented.
- Provide direction and advice to staff responsible for control implementation including Business and Department Heads.
- Review security policy violations, security breaches and errors in the result of processing.
- Allocate resources to maintain the ISMS framework, where required.

CS5292 W6 · D03 · sanitised for teaching

- Determine the level of acceptable risk.
- Agree and acknowledge the residual risk.
- Meet bi-annually to review the effectiveness of ISMS via a Management Review.
- Nominate and assign Information Security Team members.
- Review policies and procedures supporting ISMS.
- Monitor the effectiveness of control objectives.

7. Conduct and Frequency of Meetings

- ISMC meetings will be conducted Bi-Annually or as and when required.
- The Chairperson of the ISMC shall be the Chief Digital Officer (CDO) of XYZ-TS. Should the Chairperson be unable to attend a ISMC meeting, he/she shall delegate his/her responsibility (but not accountability) to another member to chair the meeting.
- If a member of the ISMC is unable to attend a meeting, the member may, with the agreement of the Chairperson, select an alternate to attend on his/her behalf.
- The required quorum for a ISMC meeting shall be four (4) standing members including IS Officer.
- The chairperson may invite other persons relevant to the business of the ISMC meeting to attend the meeting including external professionals as deemed fit.
- In discharging their responsibilities, all members of the ISMC shall adhere to the external regulatory and internal control and policy restrictions that are in force pertaining to the conduct of the business of XYZ-TS.
- All decisions and/or recommendations of the ISMC shall be adopted by unanimous agreement of the standing members.

8. Inputs to the ISMC

The following will be taken as the agenda for the ISMC meeting:

- The status of actions from previous management reviews.
- Changes in external and internal issues that are relevant to the ISMS.

CS5292 W6 · D03 · sanitised for teaching

- Changes in needs and expectations of interested parties that are relevant to the information security management system;
- Feedback on the information security performance; including trends in:
  - Nonconformities and corrective actions.
  - Monitoring and measurement results.
  - Audit results; and
  - Fulfillment of information security objectives.
- Feedback from interested parties.
- Results of risk assessment and status of risk treatment plan; and
- Opportunities for continual improvement.

9. Outputs to the ISMC

- The outputs of the ISMC shall include decisions related to continual improvement opportunities and any need for changes to the information security management system.

10. Reporting

- All major recommendations of the ISMC shall be subject to XYZ-TS Senior Management approval.
- The ISMC reports to the Board Audit Committee (BAC).

11. Support

- ISMC secretary shall be appointed, and minutes of all proceedings detailing discussion and decisions taken should be prepared and duly documented. Any such minute's purporting to be signed by the chairperson of the meeting at which the proceedings were had, or by the chairperson of the next succeeding meeting, shall be evidence of such proceedings.

CS5292 W6 · D03 · sanitised for teaching